

*Third-Party Vendor Attack · POS Malware · 40 Million Cards Stolen*

 **THIS PROJECT:** Understand what happened, map the attack, research the CVE. This project ends with a CVE Research Worksheet (50 points).

 **CVE / ADVISORY:** No CVE — social engineering entry via HVAC vendor. Research CISA Alert AA18-336A.

## INCIDENT OVERVIEW

In November–December 2013, attackers compromised retail giant Target Corporation through a third-party HVAC vendor, Fazio Mechanical Services. By stealing the vendor's network credentials through a phishing email, attackers moved into Target's corporate network, deployed point-of-sale (POS) malware called BlackPOS, and over 19 days silently exfiltrated the credit and debit card data of 40 million customers plus personal information of 70 million additional customers. Target's own FireEye security system fired alerts — and the security team ignored them. The breach cost Target over \$292 million and the CEO resigned.

## KEY FACTS AT A GLANCE

- 40 million credit/debit card numbers stolen + 70 million personal records exposed
- Entry point: Phishing email to HVAC vendor Fazio Mechanical — stole their VPN credentials
- Attack duration: 19 days of active exfiltration before shutdown
- FireEye alerts fired and were IGNORED by Target's security operations team
- Malware: BlackPOS (also called Kaptoxa) — scraped card data from POS terminal memory
- Cost to Target: \$292 million in settlements, expenses, and remediation
- CEO Gregg Steinhafel resigned in May 2014

PROJECT 1 · DAY 1

MONDAY — INCIDENT INTRODUCTION + CIA TRIAD

1–2 HRS

 **OBJECTIVE:** Students understand the Target Data Breach at a high level and apply the CIA Triad to identify which pillars were violated and how.

PROJECT 1 · DAY 2

TUESDAY — CYBER KILL CHAIN — ALL 7 PHASES

1-2 HRS

 **OBJECTIVE:** Students map the complete attack through all 7 Kill Chain phases using specific incident evidence.

PROJECT 1 · DAY 3

WEDNESDAY — MITRE ATT&CK — HANDS-ON LAB

1-2 HRS

 **OBJECTIVE:** Students identify specific ATT&CK techniques, navigate [attack.mitre.org](https://attack.mitre.org), and explain each technique in plain English.

PROJECT 1 · DAY 4

THURSDAY — CVE RESEARCH LAB + WORKSHEET  
SUBMISSION (50 PTS)

1-2 HRS

 **OBJECTIVE:** Students research the CVE or CISA advisory, build the incident timeline, finalize and submit the CVE Research Worksheet.

 **DUE:** Thursday of this project. Submit to your instructor.

**[10 pts]** What is the CVE number and CVSS score for this incident? If no CVE exists, what CISA advisory or identifier applies? What does the CVSS score (or the absence of a CVE) tell you about the nature of this vulnerability?

---

---

---

---

**[10 pts]** Describe the vulnerability or weakness in your own words — plain English, no jargon. A non-technical reader should completely understand what went wrong.

---

---

---

---

**[10 pts]** When was the official patch or fix released? How much time passed between the fix being available and the breach occurring? What does that timeline tell you about the organization's security practices?

---

---

---

---

**[10 pts]** Who was involved in containing this incident? What specific actions were taken? How long did full containment take?

---

---

---

---

**[10 pts]** List your 3 most critical "From Here On Out" recommendations for any organization that uses similar technology. For each, explain specifically WHY it would have prevented or reduced this breach.

---

---

---

---

## REFERENCES & RESOURCES

- U.S. Senate Commerce Committee: "A Kill Chain Analysis of the 2013 Target Data Breach" (2014)
- Krebs on Security: "Target Hackers Broke in Via HVAC Company" — [krebsonsecurity.com](http://krebsonsecurity.com)
- CISA Alert AA18-336A: Point-of-Sale Malware — [cisa.gov](http://cisa.gov)
- MITRE ATT&CK: [attack.mitre.org](http://attack.mitre.org) — search T1566, T1078, T1041
- NIST Cybersecurity Framework: [nist.gov/cyberframework](http://nist.gov/cyberframework)
- PCI Security Standards: [pcisecuritystandards.org](http://pcisecuritystandards.org)

